EXPERIMENT 12

SECURITY AND GOVERNANCE

Student Name: Ajayshankar Giridharan **Roll Number:** 21401007

1. Aim

To examine role-based access design and governance controls for the existing loan application in Zoho Creator.

2. Objectives

• Describe roles and permission sets.
• Review least-privilege access for Admin, Loan Officer, and Applicant.
• Identify security checks that require runtime testing.
• Document the difference between saved configuration and verified access behaviour.

3. Platform and Application Context

Platform: Zoho Creator
Application: Loan Application & Pre-Screening Management
Form: Loan_Application_Form
Report: Loan_Application_Report
Student Roll No.: 21401007

4. Theory

Security combines authentication, authorization, data-sharing rules, least privilege, auditability, and controlled API/integration access. A role hierarchy and a permission set serve different purposes: roles can affect organizational/record hierarchy, while permission sets define allowed operations. Runtime access depends on user assignment and sharing configuration as well as the saved permission settings.

5. Procedure

1. Review the documented role hierarchy: CEO > Admin > Loan Officer > Applicant.
2. Review the Admin, Loan Officer, and Applicant permission sets already documented in Experiment 8.
3. Check that API access is disabled where intended and peer sharing is not enabled for the new roles.
4. Prepare a role-permission matrix for submit, view, edit, delete, dashboard, and help access.
5. If test users are authorized and available, assign each role and verify in separate sessions; otherwise record runtime testing as pending.

6. Observations / Test Results

Area	Observation	Status / limitation
Existing configuration	Experiment 8 records roles and permission sets saved; API access disabled in the new sets.	Configuration documented.
User assignment	Experiment 8 says no users were invited or assigned.	Pending.
Runtime verification	Separate Admin, Loan Officer, and Applicant login sessions were unavailable in the prior experiment.	Not verified.
Governance	Least privilege, data-sharing review, and periodic access audit are recommended.	Review required when users are assigned.

7. Result

The experiment documents the intended security design and highlights the remaining verification requirement: assigning authorized test users and checking effective access under the applicable data-sharing rules.

8. Conclusion

Saved roles and permission sets do not prove effective access. Security must be verified with test users and least-privilege checks before the app is used with real applicant data.

Role-permission summary

Action	Admin	Loan Officer	Applicant
Submit application	Yes (intended)	No	Yes

Action	Admin	Loan Officer	Applicant
View report	Yes	Yes, for records permitted by sharing rules	No (per documented design)

Action	Admin	Loan Officer	Applicant
Edit records	Yes	Yes, within permitted records	No
Delete records	Yes	No	No
API access	Disabled in new permission set	Disabled	Disabled

9. Evidence

The figure below is a generated explanatory schematic based on the documented experiment context. It is clearly labeled illustrative and is not a captured screenshot of a live deployment or a claim that untested actions succeeded.

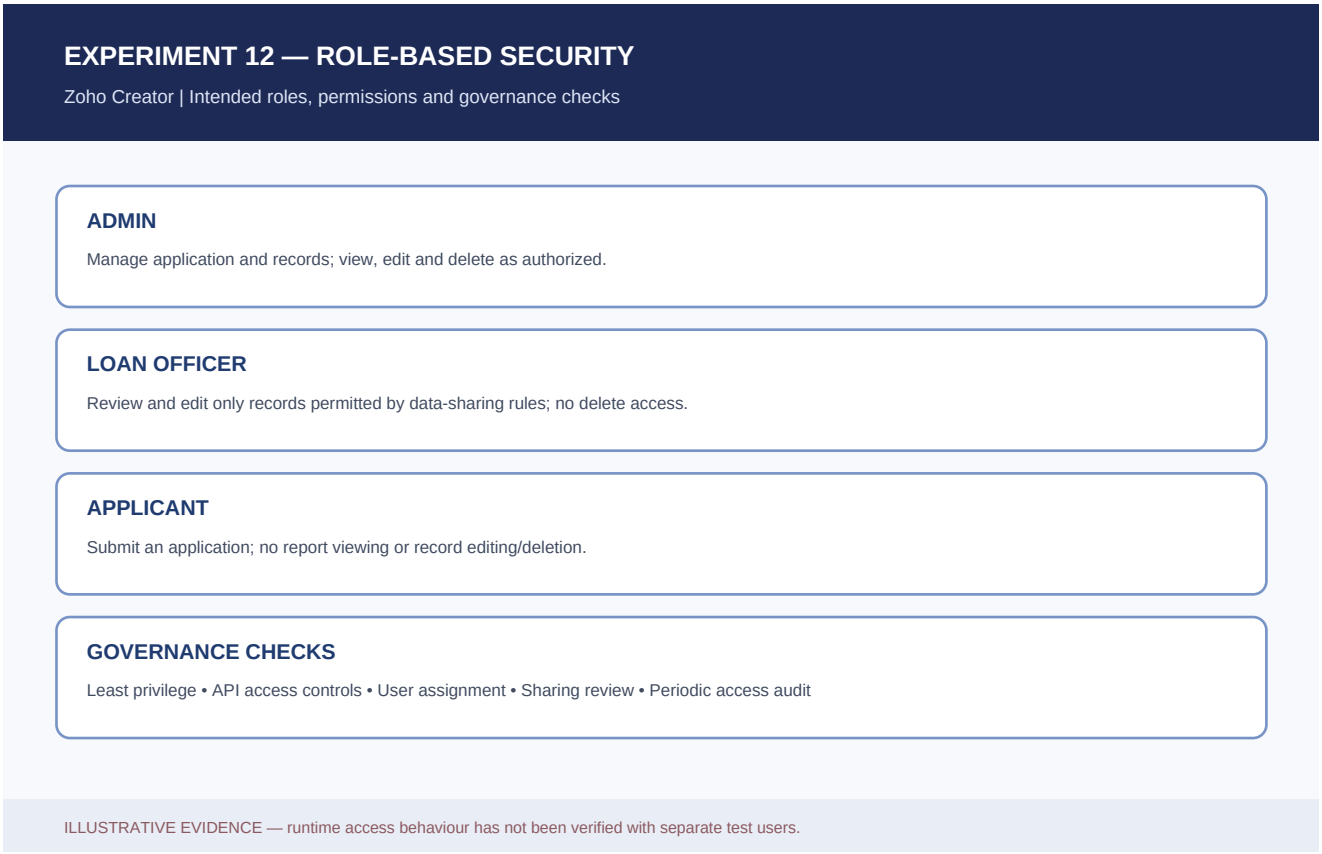

Figure 12.1 — Illustrative role-based access design; prior Experiment 8 documentation supports the configuration status and unverified runtime access.

Submission note: Where the experiment requires live configuration evidence, replace or supplement this schematic with your own screenshot from Zoho Creator/Catalyst after completing the corresponding step. Do not submit the schematic as a real system screenshot.